TLP:CLEAR

THREAT INTELLIGENCE REPORT

Who Is Being DDoSed via TCP Reflection: Sensor-Network Observations, April–October 2026

TCP SYN-ACK reflection | Source-address spoofing | Campaign against Russian organisations | Banks, ISPs, IT

Parameter	Value
Observation period	22 April — 12 October 2026 (UTC)
Analysis date	12 October 2026
Classification	TLP:CLEAR
Activity type	DDoS: TCP SYN-ACK reflection (T1498.002)
Threat level	HIGH
Data source	Sensor network in several countries including Russia; 180 days of zeek conn logs, passive frame capture
Campaigns	Background layer since 24 April (gaming and DDoS-protected hosting worldwide); Russian campaign since 18 August (22 organisations in 8 weeks)
Largest victims	Promsvyazbank (31 Aug), Bank Uralsib (29 Sep), Lukoil-Inform (5 Oct), Rostelecom and Mosgortelecom (18–19 Sep), Yandex (11 Oct), NB Trust and VK Cloud (12 Oct)
Attribution	Origin not recoverable from headers (spoofing, randomised TTL/options); no public claims of responsibility found

1. Executive Summary

Since late April 2026 the sensor network has continuously registered streams of TCP SYN packets with forged source addresses — the trace of TCP SYN-ACK reflection DDoS attacks. The forged address in such packets is the victim's address, so the list of targets under attack at any moment can be reconstructed from them. Such streams were present on 130 of the 165 observed days.

Two layers stand out. A background layer since April is the classic picture of commercial booter services: the targets are gaming and DDoS-protected hosting providers worldwide (Amarutu, ReliableSite, Amanah, DigitalOcean, Scaleway, WorldStream). A separate campaign since 18 August 2026 is directed at Russian organisations: ISPs, banks, payment and IT companies, the oil industry — 22 organisations in eight weeks.

The Russian campaign is run with one tool and, by all signs, by one operator: every wave from August to October carries the same pool of TCP fingerprints, the same replay mechanics and the same header randomisation. Its packets were observed only by sensors located in Russia — the reflectors for it are selected inside the country, so geo-filtering does not help the victim.

The largest victims: Promsvyazbank (31 August, the peak of the whole period), Bank Uralsib (29 September), Lukoil-Inform (5 October), Rostelecom and the Moscow city telecom agency Mosgortelecom (18–19 September), 42 production load balancers of Yandex (11 October, 18:56–20:26 UTC), National Bank Trust and VK Cloud (12 October).

The origin of the attacks cannot be recovered from packet headers: addresses are forged, TTL and TCP options are randomised. No public claims of responsibility for these targets were found. The target profile and timing point to pro-Ukrainian hacktivists or DDoS-for-hire; there is no confirmation. Sensor addresses and operators are not disclosed in this report.

2. Observation Method

A TCP SYN-ACK reflection attack works as follows: the attacker sends SYN packets with a forged source address to many hosts with open TCP ports; each host replies with a SYN-ACK to the forged address, and the victim receives a flood of SYN-ACKs from thousands of legitimate servers. A sensor that receives such a packet sees the victim directly in the source field. The sensors drop these packets and send nothing to the forged address, but log them fully through zeek, so the target list is reconstructed without taking part in the attack.

A reflection stream differs from background scanning by four signs, and all four were checked on every wave:

- Replay of the same packet. Hundreds of SYNs with an identical quadruple (source, source port, target, target port) within milliseconds, with identical IP ID, sequence number and TCP timestamp. A real stack never does this: retransmissions come at 1–3 s intervals and with new numbers.
- TTL mismatch. In one wave the SYN "from" the victim's address arrived with TTL 17 or 30, while the RST from the victim's real host (its reply to SYN-ACKs arriving from reflectors) came with TTL 59. The packets travelled from different hosts along different paths.
- Impossible source port. A normal client does not open connections from port 80 or 443; in reflected streams against web front ends this is the norm, because the source port of the forged SYN is the victim's attacked port.
- The victim as a whole. The addresses of one wave cover one /24 or one autonomous system (dozens of hosts of one organisation), not a random set.

In zeek this traffic produces connections with history ShR or S0, orig_bytes = 0 and orig_pkts ≥ 3; nothing happens at the application layer. The chronology was built from the 180-day archive of conn logs of all

sensors, network attribution from RIPEstat, reverse DNS through public resolvers. Address spoofing was confirmed by passive frame-level capture during a live wave on 12 October.

3. Chronology: Two Layers

3.1. Background layer (since 24–30 April, all sensors, reflector port mostly 23/tcp)

Short waves of 1–3 days against a single host; the victims are game servers, VPNs and DDoS-protected hosting. Examples: Amarutu Technology (NL) — the same host under attack for 95 consecutive days from June to October and a second host on 7–14 July; ReliableSite (US) — June to August; Amanah Tech (CA) — 1–12 October; DigitalOcean, Scaleway, WorldStream, Leaseweb UK, GigeNET, Oracle Cloud, RoEduNet (RO), WHG Hosting, Web Werks (IN), SpectraIP, Dedicated Telekomunikasyon (TR). The layer peaked in the first week of May.

3.2. Russian campaign (since 18 August, Russia-located sensors only, reflector port 3306/tcp)

Longer waves (1–3 days); the targets are whole autonomous systems of Russian companies, often dozens of hosts of one network at a time. The reflector port differs from the background layer: the reflector list for this campaign was built by a separate scan of Russian address space. Pauses between waves are 1–9 days. Target profile: banks (3), ISPs and telecom operators (6), hosting and IT (8), a payment institution, logistics, an oil-industry IT company.

Period	Victim	AS	Targeted networks	Connections
18–20 Aug	Omskie Kabelnye Seti (Omsk ISP)	AS47165	109.120.20.0/24, 176.62.66.0/24, 176.62.67.0/24	≈1,700
20 Aug	SKB Kontur	AS49675	46.17.206.0/24	233
25 Aug	Selectel; CDEK	AS49505; AS42524	92.53.101.0/24; 195.189.222.0/24	519; 27
26 Aug	Teleport Telecom	AS39153	80.253.17.0/24, 80.253.21.0/24	344
27–29 Aug	Malnet	AS47156	213.5.24.0/24, 213.5.31.0/24	≈7,000
31 Aug	Promsvyazbank	AS42231	91.223.63.0/24, 193.200.10.0/24	4,728 (peak)
2 Sep	GranLine	AS203806	195.209.48.0/24, 46.22.52.0/24	158
3 Sep	Necstel	AS61068	185.20.46.0/24, 185.9.79.0/24	426
7 Sep	Elecsnet (payment NCO)	AS206973	91.225.194.0/23	2,267
8–9 Sep	TIS Dialog (Kaliningrad)	AS31214	83.219.130.0/24, 83.219.134.0/24, 83.219.149.0/24	>5,000*
18–19 Sep	Rostelecom; Mosgortelecom	AS12389; AS8901	95.167.231.0/24; 212.11.158.0/24	≈5,000

25 Sep	Intek-Mytischi	AS57456	45.152.122.0/24, 31.135.94.0/24	491
26 Sep	Selectel (MSK), port 443	AS50340	5.178.85.0/24	101
29 Sep, 1 Oct	Bank Uralsib	AS21252, AS20872	193.109.114.0/24, 195.234.190.0/24	>5,000* + 410
2 Oct	Site LLC	AS30745	89.232.144.0/20	180
5 Oct	Lukoil-Inform	AS13105	95.171.229.0/24, 95.171.232.0/24	3,412
7 Oct	Masterhost	AS25532	90.156.201.0/24	1,121
8–9 Oct	EKMA IS	AS51518	91.217.78.0/23	1,414
11 Oct 18:56–20:26 UTC	Yandex, 42 public VIPs	AS13238	213.180.193.0/24, 213.180.204.0/24, 87.250.250.0/24, 87.250.251.0/24, 93.158.134.0/24, 5.45.196.0/24 and others	1,321
12 Oct (to 12:00 UTC)	NB Trust; VK Cloud; VDSina (port 443)	AS39850; AS47764; AS216071	194.226.143.0/24; 146.185.243.52; 91.84.104.0/24	≈1,100; S0 without RST; 142

"Connections" is the number of connections recorded by a single sensor; the real volume of the attack on the victim is orders of magnitude higher (thousands of reflectors). Waves marked with an asterisk hit the export limit.

4. Tool and Operator

All waves of the Russian campaign carry the same set of traits:

- TCP fingerprint pool (JA4T). Dominated by 64240_2-4-8-1-3_1460_7 (the Linux default), alongside 29200_2-4-8-1-3_1460_7, 64240_2-1-3-1-1-4_1460_8, 65535_2-4-8-1-3_1460_9, 32120_2-1-1-4-1-3_1460_10. The same pool from the Rostelecom wave to the Trust wave. The values are plausible (MSS 1410/1380/1400 are typical of VPN and PPPoE MTUs): the tool imitates heterogeneous clients.
- Header randomisation. TTL of different forged tuples within one wave is 17, 30, 52 for the same target; windows 8192, 42300, 65535. Had a single node sent with a fixed TTL, the values would match; 34–47 hops do not occur on the Internet. The TTL is set randomly and the distance to the attacker cannot be estimated from it.
- Raw-socket crafting. The same packet is repeated 84–107 times within milliseconds with identical IP ID, seq and TSval — a script does this, not a kernel.
- Source port from the target list. The port class changes from wave to wave: Uralsib — high ports only, Yandex — 80/443 only, EKMA — mostly below 1024, Trust — a mix.
- Reflectors inside Russia. The campaign's packets were observed only by sensors in Russia; sensors in Europe and the US saw only the background layer. For the victim this means a SYN-ACK flood from Russian addresses, against which geo-blocking is useless.
- Attacker infrastructure. Address spoofing requires an uplink without source filtering (BCP 38) — a VPS or dedicated server at a hoster without egress filtering, not a home botnet.

The background layer uses the same techniques (replays, port 23 as reflector) but different reflector lists and different target classes — probably several independent booter services.

5. The 11 October Wave: Yandex Load Balancers

On 11 October from 18:56 to 20:26 UTC the reflection stream included 42 public addresses of Yandex production services: by reverse DNS these are startup-balancer.stable.qloud-b, eats-superapp-authproxy.eda, ott-api-production-balancer.ott, external-hq-api.plus, core-renderer-staticapi.maps, external-promo.plus (all under yandex.net) and others. The forged source ports were 80 and 443, i.e. the HTTP/HTTPS front ends were attacked. Mechanically the wave is indistinguishable from the waves against Uralsib or Trust: the same fingerprint pool, the same replays, the same duration of about an hour and a half.

6. Limitations and Attribution

- The source address is forged by definition; TTL, windows and options are randomised. The real sender can only be recovered by traceback through provider uplinks.
- The volumes in the table are the observation of a single reflector; they are suitable for comparing waves with each other, not for estimating attack power.
- Victims whose stack does not answer an unsolicited SYN-ACK with RST (for example VK Cloud on 12 October) are visible only as S0 and are undercounted in RSTO-based counts.
- Open sources: the public IT Army of Ukraine channel does not publish targets (it distributes them through its own tool), monitoring of hacktivist and criminal Telegram channels yielded no mentions of these victims for the period, and there are no news reports of attacks on Uralsib, Lukoil, Trust or Yandex on these dates. The target profile and timing point to pro-Ukrainian hacktivists or DDoS-for-hire; there is no confirmation.

7. Recommendations

- Network operators and hosters: egress filtering of forged sources (BCP 38 / uRPF). Without it, hosting becomes the launch pad for such campaigns.
- Victims: a SYN-ACK flood from thousands of different addresses to port 80/443 is reflection, not an attack "from" those addresses. Blocking the senders is pointless and a geo-filter on Russia will not help (the reflectors are Russian). What works is connection-state filtering (a SYN-ACK without a preceding SYN is dropped at the edge) and anti-DDoS with state verification.
- Owners of open TCP services: rate-limit repeated SYNs of one (source, source port, destination port) tuple (for example no more than three per second) — a legitimate client never hits such limits, while reflection through your host stops. Separately close UDP amplifiers (SNMP, DNS, NTP, memcached) or limit them per source.
- Analysts: the set of signs in section 2 makes it possible to tell reflection from reconnaissance and not to publish victims as "scanners" — an error easy to make from raw logs.

8. Appendix: Signatures and Data

- zeek conn: conn_state ShR→RSTO or S0, orig_bytes = 0, orig_pkts ≥ 3, repetition of the tuple (id.orig_h, id.orig_p, id.resp_p) at least three times per day. Half-open scans (masscan, zmap) are excluded by the condition orig_pkts ≥ 3 and the absence of tuple repeats.
- Frame-level confirmation of spoofing: TTL of the incoming SYN differs from the TTL of the RST of the same address; identical IP ID across a series of SYNs; inter-packet interval 0 ms.
- Attribution: RIPEstat prefix-overview, PTR through public resolvers.
- MITRE ATT&CK: T1498.002 (Network DoS: Reflection Amplification), T1498 (Network Denial of Service), T1583.003 (Acquire Infrastructure: Virtual Private Server), T1595.001 (Active Scanning: Scanning IP Blocks — building the reflector list).

TLP:CLEAR — This document may be distributed without restriction.